

1 ОРГАНИЗАЦИОННО-ПРАВОВОЕ ОБЕСПЕЧЕНИЕ ИБ

Выпускная квалификационная работа выполнялась с учётом требований действующего законодательства Российской Федерации, которое регулирует область применения разрабатываемого средства обнаружения аномалий в Kubernetes-кластере на основе нейронных сетей.

Разрабатываемое программное средство предназначено для анализа audit-логов Kubernetes-кластера, формируемых компонентом kube-apiserver, выявления аномального поведения пользователей и service-account, а также передачи соответствующих уведомлений в систему реагирования на инциденты.

Kubernetes-кластер обладает рядом особенностей, которые определяют специфику его правового и организационного регулирования. Audit-логи Kubernetes могут содержать сведения о действиях пользователей, идентификаторы учётных записей, IP-адреса, параметры запросов к API и другие данные, которые в ряде случаев могут быть отнесены к персональным данным или служебной информации ограниченного доступа. В связи с этим необходимо учитывать требования законодательства в области защиты информации, персональных данных, а также обеспечения безопасности критической информационной инфраструктуры.

В рамках данной работы не представляется возможным проанализировать все нормативные правовые акты, поэтому далее рассматриваются наиболее важные из них, имеющие непосредственное отношение к теме исследования:

- Конституция Российской Федерации;
- Федеральный закон от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации»;
- Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных»;
- Постановление Правительства Российской Федерации от 01.11.2012 № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных»;
- Приказ ФСТЭК России от 18.02.2013 № 21 «Об утверждении Составы и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных»;

- Приказ ФСТЭК России от 11.04.2025 № 117 «Об утверждении Требований о защите информации, содержащейся в государственных информационных системах, иных информационных системах государственных органов, государственных унитарных предприятий, государственных учреждений»;
- Федеральный закон от 26.07.2017 № 187-ФЗ «О безопасности критической информационной инфраструктуры Российской Федерации»;
- Уголовный кодекс Российской Федерации;

1.1 Конституция Российской Федерации

Конституция Российской Федерации является основным нормативным правовым актом, обладающим высшей юридической силой. Именно её положения формируют базовые принципы обращения с информацией, обеспечением неприкосновенности частной жизни и защитой прав граждан в информационной сфере. В частности, Конституция закрепляет право каждого на неприкосновенность частной жизни, личную и семейную тайну, защиту своей чести и доброго имени, а также устанавливает свободу поиска, получения, передачи, производства и распространения информации любым законным способом.

В контексте обработки audit-логов Kubernetes-кластера особенно актуальны следующие статьи Конституции РФ:

- **Статья 23** — закрепляет право каждого на неприкосновенность частной жизни, личную и семейную тайну, защиту своей чести и доброго имени. Это означает, что любые данные, которые позволяют идентифицировать действия конкретного пользователя или служебной учётной записи, должны обрабатываться с соблюдением принципа конфиденциальности.
- **Статья 24** — устанавливает, что сбор, хранение, использование и распространение информации о частной жизни лица без его согласия не допускаются. В контексте разработки системы обнаружения аномалий это накладывает требования к анонимизации или псевдонимизации персональных данных, а также к ограничению доступа к audit-логам только уполномоченным сотрудникам.

Таким образом, при проектировании и внедрении системы обнаружения аномалий необходимо учитывать конституционные принципы, обеспечивающие защиту персональной и служебной информации. Любые действия по анализу и обработке логов должны быть законными, прозрачными и документированными, с соблюдением требований по минимизации сбора и обработки личных данных. Реализация программного средства обнаружения аномалий в Kubernetes-кластере должна строиться с учетом следующих конституционных принципов:

- 1) Обеспечение конфиденциальности персональных данных пользователей и служебной информации.
- 2) Законность и прозрачность методов сбора и обработки данных.
- 3) Ограничение доступа к информации только уполномоченным лицам.
- 4) Документирование всех процедур обработки логов с целью соблюдения права граждан на защиту своей частной жизни.

1.2 Федеральный закон № 149-ФЗ «Об информации, информационных технологиях и о защите информации»

Федеральный закон № 149-ФЗ «Об информации, информационных технологиях и о защите информации» является базовым нормативным правовым актом, регулирующим отношения, возникающие при осуществлении права на поиск, получение, передачу, производство и распространение информации, а также при применении информационных технологий и обеспечении защиты информации. Данный закон конкретизирует конституционные положения в сфере обращения с информацией и определяет правовые основы её использования в информационных системах.

В соответствии со статьей 2 Федерального закона № 149-ФЗ под информацией понимаются сведения (сообщения, данные) независимо от формы их представления, а информационная система рассматривается как совокупность содержащейся в базах данных информации и обеспечивающих её обработку информационных технологий и технических средств. Указанные определения имеют непосредственное значение для разрабатываемого программного средства, поскольку Kubernetes-кластер и связанные с ним audit-логи могут рассматриваться как часть информационной системы, в которой осуществляется сбор, хранение и обработка данных о действиях пользователей и сервисных учётных записей.

Статья 5 указанного закона устанавливает, что информация может являться объектом публичных, гражданских и иных правовых отношений, а также может свободно использоваться и передаваться, если федеральными законами не установлены ограничения доступа к ней либо иные требования к порядку её предоставления или распространения. Для рассматриваемой работы это означает, что audit-логи могут использоваться в целях мониторинга и анализа только при соблюдении установленного режима доступа и требований к защите сведений, содержащих ограниченно доступную информацию.

Особое значение для темы исследования имеет статья 16 Федерального закона № 149-ФЗ, согласно которой защита информации представляет собой принятие правовых, организационных и технических мер, направленных на обеспечение защиты информации от неправомерного доступа, уничтожения, модифицирования, блокирования, копирования, предоставления и распространения, а также на соблюдение конфиденциальности информации ограниченного доступа. Следовательно, при разработке системы обнаружения аномалий в Kubernetes-кластере необходимо предусмотреть меры по разграничению доступа к логам, защите каналов передачи данных, контролю целостности хранимой информации и ограничению несанкционированного использования результатов анализа.

Таким образом, Федеральный закон № 149-ФЗ формирует правовую основу для обработки audit-логов Kubernetes-кластера как информации, подлежащей правовому режиму и защите. При проектировании и внедрении разрабатываемого решения должны быть обеспечены законность обработки данных, соблюдение ограничений доступа, а также применение организационных и технических мер защиты информации в соответствии с действующим законодательством Российской Федерации.

1.3 Федеральный закон № 152-ФЗ «О персональных данных»

Федеральный закон № 152-ФЗ «О персональных данных» устанавливает правовые основы обработки персональных данных и направлен на обеспечение защиты прав и свобод человека и гражданина при обработке его персональных данных, включая защиту прав на неприкосновенность частной жизни, личную и семейную тайну. Данный закон развивает положения Конституции Российской Федерации и конкретизирует требования к работе с данными, позволяющими идентифицировать субъекта.

Согласно статье 3 Федерального закона № 152-ФЗ персональные данные представляют собой любую информацию, относящуюся прямо или косвенно к определённому или определяемому физическому лицу (субъекту персональных данных), а обработка персональных данных включает любые действия с ними, в том числе сбор, запись, систематизацию, накопление, хранение, уточнение, использование и передачу. Оператором персональных данных является лицо, самостоятельно или совместно с другими лицами организующее и осуществляющее обработку данных, а также определяющее цели такой обработки.

В контексте разрабатываемого программного средства анализ audit-логов Kubernetes-кластера может затрагивать персональные данные, поскольку такие логи могут содержать идентификаторы пользователей, IP-адреса, временные метки, сведения о действиях в системе и другие атрибуты, позволяющие прямо или косвенно установить связь с конкретным субъектом. В соответствии со статьёй 5 закона обработка персональных данных должна осуществляться на законной и справедливой основе, ограничиваться достижением конкретных, заранее определённых и законных целей, а также не допускать избыточности обрабатываемых данных по отношению к заявленным целям.

Статья 6 Федерального закона № 152-ФЗ определяет условия обработки персональных данных, включая необходимость получения согласия субъекта либо наличие иных законных оснований для обработки. В случае использования системы обнаружения аномалий в рамках обеспечения информационной безопасности допускается обработка персональных данных без согласия субъекта, если это необходимо для достижения целей, предусмотренных законодательством, при условии соблюдения прав и законных интересов субъектов данных.

Особое значение имеет статья 19, устанавливающая обязанность оператора принимать необходимые правовые, организационные и технические меры для защиты персональных данных от неправомерного или случайного доступа, уничтожения, изменения, блокирования, копирования и распространения. К таким мерам относятся, в частности, разграничение прав доступа, использование средств защиты информации, а также контроль и аудит действий пользователей.

Таким образом, при разработке и внедрении системы обнаружения аномалий в Kubernetes-кластере необходимо учитывать требования Федерального закона № 152-ФЗ, включая минимизацию обрабатываемых данных, определение целей обработки, обеспечение законных оснований обработки и реализацию комплекса мер по защите персональных данных. Особое внимание должно уделяться возможности ограничению доступа к audit-логам, что позволяет снизить риски нарушения прав субъектов персональных данных.

1.4 Постановление Правительства Российской Федерации № 1119

Постановление Правительства Российской Федерации от 01.11.2012 № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных» устанавливает требования к обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных (ИСПДн). Данный нормативный акт конкретизирует положения Федерального закона № 152-ФЗ и определяет подходы к выбору и реализации мер защиты информации.

В соответствии с постановлением вводится понятие уровня защищённости персональных данных, который определяется в зависимости от категории обрабатываемых персональных данных, количества субъектов персональных данных, а также актуальных угроз безопасности. Выделяются четыре уровня защищённости, для каждого из которых устанавливается необходимый состав организационных и технических мер по защите информации.

Для разрабатываемого программного средства данный нормативный акт имеет практическое значение в тех случаях, когда система анализа audit-логов Kubernetes-кластера используется в составе ИСПДн или обрабатывает данные, которые могут быть отнесены к персональным. В такой ситуации необходимо определить актуальный уровень защищённости системы и реализовать соответствующий ему набор мер защиты.

К числу таких мер относятся:

- обеспечение контроля доступа в помещения, где размещены информационные системы с ПД, чтобы исключить неконтролируемое проникновение посторонних лиц;
- утверждение руководителем оператора документа, в котором чётко прописано, кто и на каком основании имеет доступ к персональным данным;

- регистрация и учёт событий безопасности, включая действия пользователей и администраторов;
- использование сертифицированных средств защиты информации (СЗИ);

Таким образом, Постановление Правительства РФ № 1119 определяет необходимость формального подхода к оценке защищённости системы и выбору мер защиты персональных данных. При внедрении системы обнаружения аномалий необходимо учитывать уровень защищённости ИСПДн и обеспечивать соответствие реализуемых механизмов требованиям данного нормативного акта.

1.5 Приказ ФСТЭК России № 21

Приказ ФСТЭК России от 18.02.2013 № 21 «Об утверждении Составы и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных» является одним из ключевых подзаконных актов, конкретизирующих требования к защите персональных данных в информационных системах персональных данных. Данный нормативный документ устанавливает состав мер, необходимых для обеспечения безопасности персональных данных, и определяет подходы к их реализации в зависимости от уровня защищённости информационной системы.

В соответствии с приказом № 21 все меры защиты подразделяются на организационные и технические и охватывают полный жизненный цикл обработки персональных данных. К основным группам мер относятся:

- **Идентификация и аутентификация субъектов доступа** — обеспечение однозначного установления личности пользователей и процессов, имеющих доступ к информационной системе, включая применение механизмов аутентификации и управление учётными записями.
- **Управление доступом** — разграничение прав доступа пользователей и процессов к информационным ресурсам в соответствии с их полномочиями, реализация принципа минимально необходимых привилегий, а также контроль доступа к данным и функциям системы.
- **Ограничение программной среды** — предотвращение запуска несанкционированного программного обеспечения, контроль состава и целостности используемых программных компонентов.

- **Защита машинных носителей информации** — обеспечение контроля доступа к носителям информации, предотвращение несанкционированного копирования и утечки данных.
- **Регистрация событий безопасности** — ведение журналов событий, связанных с доступом к системе и действиями пользователей, включая фиксацию попыток несанкционированного доступа, изменений конфигурации и иных значимых событий.
- **Антивирусная защита** — применение средств защиты от вредоносного программного обеспечения и контроль их актуальности.
- **Обнаружение вторжений** — выявление попыток несанкционированного доступа и иных инцидентов безопасности на основе анализа событий и поведения пользователей.
- **Контроль целостности** — обеспечение неизменности программного обеспечения и данных, включая контроль целостности журналов регистрации событий.
- **Обеспечение доступности** — защита системы от отказов и сбоев, а также обеспечение возможности восстановления работоспособности.
- **Защита среды виртуализации** — обеспечение безопасности виртуальных инфраструктур, включая изоляцию компонентов и контроль взаимодействия между ними.

Перечисленные меры формируют комплексную систему защиты информации и направлены на предотвращение, выявление и реагирование на инциденты информационной безопасности.

Для темы ВКР данный приказ имеет особое значение, поскольку разрабатываемое средство основано на анализе audit-логов Kubernetes-кластера, то есть на сборе, регистрации и последующей обработке событий, связанных с действиями пользователей и сервисных учётных записей. Это напрямую соответствует требованиям по регистрации событий безопасности и обнаружению вторжений, установленным приказом № 21.

В контексте Kubernetes-кластера указанные меры могут быть реализованы следующим образом:

- механизмы идентификации и аутентификации — через средства аутентификации Kubernetes;
- управление доступом — с использованием ролевой модели доступа (RBAC);

- регистрация событий — посредством audit-логирования kube-apiserver;
- обнаружение вторжений — с использованием разработанной системы анализа аномалий;
- контроль целостности — через защиту журналов и централизованные системы хранения логов.

1.6 Приказ ФСТЭК России № 117

Приказ ФСТЭК России от 11.04.2025 № 117 «Об утверждении Требований о защите информации, содержащейся в государственных информационных системах, иных информационных системах государственных органов, государственных унитарных предприятий, государственных учреждений» устанавливает требования к защите информации в государственном секторе и в иных информационных системах, для которых предъявляются повышенные требования к обеспечению безопасности. Данный нормативный акт определяет современный подход к защите информации в информационных системах, где особенно важны устойчивость к инцидентам, контроль доступа и регистрация событий безопасности.

Для разрабатываемого решения приказ № 117 имеет значение в случае применения системы в государственных информационных системах либо в инфраструктуре организаций, находящихся в сфере государственного регулирования. В такой ситуации анализ audit-логов Kubernetes-кластера и автоматическое выявление аномалий должны рассматриваться как часть комплекса мер по защите информации.

Практическая ценность такого подхода заключается в том, что система позволяет повысить уровень наблюдаемости защищаемой среды, своевременно выявлять подозрительные действия, фиксировать нарушения установленного режима доступа и поддерживать процесс реагирования на инциденты. Таким образом, применение разрабатываемого средства соответствует общим требованиям к обеспечению безопасности информации, содержащейся в государственных и иных защищаемых информационных системах.

1.7 Федеральный закон № 187-ФЗ «О безопасности критической информационной инфраструктуры Российской Федерации»

Федеральный закон № 187-ФЗ «О безопасности критической информационной инфраструктуры Российской Федерации» регулирует отношения, возникающие при обеспечении безопасности значимых объектов критической информационной инфраструктуры (КИИ). Закон распространяется на информационные системы, информационно-телекоммуникационные сети и автоматизированные системы управления, функционирование которых имеет ключевое значение для устойчивого функционирования государства, экономики и обеспечения безопасности граждан.

К субъектам КИИ относятся организации, осуществляющие деятельность в таких сферах, как здравоохранение, транспорт, связь, энергетика, банковская и финансовая сфера, топливно-энергетический комплекс, промышленность и иные отрасли. Для таких объектов устанавливаются специальные требования по обеспечению безопасности, включая проведение категорирования объектов КИИ, выявление актуальных угроз, реализацию мер защиты и организацию процессов реагирования на компьютерные инциденты.

В соответствии с положениями закона субъекты КИИ обязаны:

- проводить категорирование объектов критической информационной инфраструктуры;
- обеспечивать реализацию организационных и технических мер по защите информации;
- осуществлять мониторинг состояния безопасности и выявление компьютерных инцидентов;
- обеспечивать взаимодействие с государственными системами обнаружения, предупреждения и ликвидации последствий компьютерных атак;
- принимать меры по предотвращению, обнаружению и ликвидации последствий компьютерных атак.

Поскольку Kubernetes-кластеры широко используются в современной корпоративной и государственной инфраструктуре, в том числе в организациях, относящихся к субъектам КИИ, данный закон имеет прямое отношение к теме выпускной квалификационной работы. Kubernetes-кластер может являться частью значимого объекта КИИ или обеспечивать функционирование критически важных сервисов.

Разрабатываемое средство обнаружения аномалий на основе анализа audit-логов Kubernetes-кластера может рассматриваться как элемент системы мониторинга безопасности значимого объекта КИИ. Оно позволяет осуществлять сбор и анализ событий, выявлять отклонения в поведении пользователей и сервисных учётных записей, обнаруживать признаки компрометации и несанкционированного доступа.

Таким образом, применение разработанного решения способствует выполнению требований Федерального закона № 187-ФЗ в части мониторинга безопасности, выявления и реагирования на инциденты, а также повышения общего уровня защищённости критической информационной инфраструктуры.

1.8 Уголовный кодекс Российской Федерации

Уголовный кодекс Российской Федерации устанавливает ответственность за преступления в сфере компьютерной информации и обеспечивает правовую защиту информационных систем от неправомерных действий. В контексте обеспечения информационной безопасности особое значение имеют статьи 272–274, регламентирующие ответственность за нарушения, связанные с несанкционированным доступом и эксплуатацией средств обработки информации.

Статья 272 УК РФ предусматривает ответственность за неправомерный доступ к компьютерной информации, если это деяние повлекло уничтожение, блокирование, модификацию либо копирование информации. Данная норма направлена на защиту конфиденциальности, целостности и доступности информации, обрабатываемой в информационных системах.

Статья 273 УК РФ устанавливает ответственность за создание, использование и распространение вредоносных программ для ЭВМ, предназначенных для несанкционированного уничтожения, блокирования, модификации или копирования информации, а также для нейтрализации средств защиты информации.

Статья 274 УК РФ регламентирует ответственность за нарушение правил эксплуатации средств хранения, обработки или передачи компьютерной информации, а также информационно-телекоммуникационных сетей, если это повлекло уничтожение, блокирование или модификацию информации и причинило существенный вред.

2 Выводы

В данной главе были рассмотрены нормативные правовые акты Российской Федерации, определяющие организационно-правовые основы обеспечения информационной безопасности при разработке и применении средств анализа audit-логов Kubernetes-кластера на основе нейронных сетей.

Установлено, что Конституция Российской Федерации закрепляет базовые права на неприкосновенность частной жизни, защиту персональной информации и законное обращение со сведениями ограниченного доступа. Эти положения формируют общую правовую основу для последующей регламентации обработки информации в информационных системах.

Федеральный закон № 149-ФЗ «Об информации, информационных технологиях и о защите информации» определяет информацию как объект правовых отношений, устанавливает классификацию информации по доступу и закрепляет необходимость её защиты от неправомерного доступа, уничтожения, модифицирования и распространения. Для разрабатываемого программного средства данный закон имеет базовое значение, поскольку audit-логи Kubernetes-кластера представляют собой информацию, требующую соблюдения установленного режима доступа и мер защиты.

Федеральный закон № 152-ФЗ «О персональных данных», а также Постановление Правительства Российской Федерации № 1119 определяют правовые основы обработки персональных данных и требования к обеспечению их безопасности в информационных системах персональных данных. В рамках рассматриваемой темы это особенно важно, поскольку audit-логи могут содержать сведения, позволяющие прямо или косвенно идентифицировать пользователя или сервисную учётную запись. Следовательно, при проектировании системы необходимо учитывать принципы минимизации, законности обработки, разграничения доступа и защиты данных.

Приказ ФСТЭК России № 21 конкретизирует состав организационных и технических мер по защите персональных данных, включая идентификацию и аутентификацию, управление доступом, регистрацию событий безопасности, контроль целостности и обнаружение инцидентов. Указанные требования непосредственно соотносятся с функциональностью разрабатываемого средства, поскольку анализ audit-логов и выявление аномалий являются частью механизма контроля безопасности информационной системы.

Федеральный закон № 187-ФЗ «О безопасности критической информационной инфраструктуры Российской Федерации» показывает значимость рассматриваемого решения для организаций, чьи информационные системы относятся к объектам критической информационной инфраструктуры. В таких условиях система обнаружения аномалий может использоваться как элемент мониторинга и реагирования на компьютерные инциденты, повышающий устойчивость защищаемой инфраструктуры.

Также было установлено, что нормы Уголовного кодекса Российской Федерации, в частности статьи 272–274, устанавливают ответственность за неправомерный доступ к компьютерной информации, создание и использование вредоносных программ, а также нарушение правил эксплуатации средств хранения, обработки и передачи информации. Это подтверждает необходимость применения средств своевременного выявления подозрительной активности и предотвращения инцидентов информационной безопасности.

Таким образом, проведённый анализ нормативных правовых актов показывает, что разработка системы обнаружения аномалий в Kubernetes-кластере на основе анализа audit-логов соответствует действующим требованиям законодательства Российской Федерации в области информации, персональных данных и защиты информации. Рассмотренные правовые нормы определяют необходимость применения организационных и технических мер защиты, обеспечивающих законность обработки данных, ограничение доступа к ним и своевременное выявление инцидентов безопасности.